ABRACADABRA MONEY · SECURITY REVIEW

Abracadabra Money USD0 Updates.

A security review of USD0 Updates.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Abracadabra Money	USD0 Updates	Guardian	December 22 – December 28, 2024	December 28, 2024

§ 00

Contents.

12 pages: overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

§ 01 Overview P. 03

§ 02 Confidence Ranking P. 04

§ 03 Scope & Classifications P. 05

§ 04 Findings P. 06

Main Review · 4 findings P. 07

§ 05 Disclaimer P. 11

§ 06 About Guardian P. 12

§ 01

Overview.

Guardian reviewed USD0 Updates across a single review round. The final report includes 1 High, 1 Medium, 2 Low findings.

AUDIT FIRM
Guardian

CLIENT
Abracadabra Money

PROJECT
USD0 Updates

PREPARED BY
Guardian

AUDIT WINDOW
December 22 – December 28, 2024

FINAL REPORT
December 28, 2024

METHODOLOGY
Smart contract · Manual · Main Review

1.1 Confidence Ranking

4 / 5

High Confidence

Guardian assigns a Confidence Ranking of 4 out of 5, combining finding severity, remediation outcome, and the reviewer's assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	**HIGH CONFIDENCE**	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	**0**	0	0	0	0
High	**1**	0	0	0	1
Medium	**1**	0	1	0	0
Low	**2**	0	0	0	2
Informational	**0**	0	0	0	0
All severities	**4**	**0**	**1**	**0**	**3**

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence ASSIGNED	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed USD0 Updates.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH	Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.
IMPACT · MEDIUM	Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.
IMPACT · LOW	Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.
LIKELIHOOD · HIGH	Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.
LIKELIHOOD · MEDIUM	Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.
LIKELIHOOD · LOW	Unlikely to ever occur in production.

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in. Status is where each finding ended up; its own page says how.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
H-01	Swapped Funds Are Trapped In The Router	—	HIGH	RESOLVED	p. 7
M-01	Harvest Extractable Value	Sandwhich Attack	MEDIUM	ACKNOWLEDGED	p. 8
L-01	Events Emitted On No Update	Events	LOW	RESOLVED	p. 9
L-02	Ownership Not Transferred In Deploy Script	Warning	LOW	RESOLVED	p. 10

HIGH **H-01** RESOLVED

Swapped Funds Are Trapped In The Router

LOCATION `MagicUSD0ppHarvester.sol`

REVIEW Main Review

DESCRIPTION

In the run function the reward tokens are transferred to the router address instead of approving the router address and allowing the router to transferFrom the harvester contract. The Odos router is planned to be used, based upon deploy scripts, and attempts to transferFrom the caller instead of relying on the router contract balance, thus any funds sent to the Odos router would be trapped.
As long as a nonzero amountOut is specified and the asset balance of the harvester is zero then this swap will simply fail rendering the harvester incapable of performing harvest actions.

RECOMMENDATION

Include optionality for whether to transfer funds to the router address or to approve the router address in the run function.

RESOLUTION

Status: Resolved.

MEDIUM M-01

ACKNOWLEDGED

Harvest Extractable Value

CATEGORY	Sandwhich Attack
LOCATION	`MagicUSD0pp.sol`
REVIEW	Main Review

DESCRIPTION

The Harvester `run` function calls distribute rewards on the `MagicUSD0pp` vault which immediately increases the value of the MagicUsd0++ shares. Given the vault exists on ethereum mainnet this value increase may be arbitraged by an actor observing the mempool for a large harvest. The attacker may deposit directly before and withdraw directly after the share value increase for risk free gain.

RECOMMENDATION

Consider introducing a deposit/withdrawal fee to ensure that a reasonable sized harvest cannot be profitably arbitraged. Otherwise consider adding logic such that the harvested rewards are distributed to the vault over time to avoid stepwise jumps in share value.

RESOLUTION

Status: Acknowledged.

LOW **L-01** RESOLVED

Events Emitted On No Update

CATEGORY	Events
LOCATION	`MagicUsd0ppHarvester.sol`
REVIEW	Main Review

DESCRIPTION

In the `setAllowedRouter` and `setFeeParameters` functions events are emitted indicating that a configuration change has taken place even when the configurations have not changed.

RECOMMENDATION

Be aware of this behavior and consider reverting/not emitting these events when the new configurations are the same as the existing configurations.

RESOLUTION

Status: Resolved.

LOW L-02

RESOLVED

Ownership Not Transferred In Deploy Script

CATEGORY	Warning
LOCATION	`MagicUsd0pp.s.sol`
REVIEW	Main Review

DESCRIPTION

In `MagicUsd0pp.s.sol` script the ownership of the vault is transferred to the `safe.ops` toolkit address, however the ownership for the harvester contract is left with the EOA executing the script.

RECOMMENDATION

Consider transferring the harvester ownership to the `safe.ops` address in the toolkit at the end of the deploy script.

RESOLUTION

Status: Resolved.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

$45B+
DIGITAL ASSETS UNDER REVIEW

200+
ENGAGEMENTS COMPLETED

500+
CRITICAL & HIGH FINDINGS REPORTED

Reach us at audits@guardianaudits.com.